Udyam Digital: privacy and security choices

Consent before KYC

- **What:** before any document upload, the owner sees a short notice (version kyc-v1.0) in their language. It lists what we collect (GSTIN, Udyam number, business proof, ID, address proof) and how long we keep it.
- **Why:** to verify the business for activation. Nothing else.
- **Withdrawal:** one tap (`DELETE /consent/{id}`). The KYC case is cancelled and its files are deleted straight away.

Purpose limitation

KYC data is used only for verification. It is never used for marketing or for the propensity model.

Data minimisation per step

Step	What we collect
Login	Phone number, language, WhatsApp opt-in (yes/no)
Advisor	Business type, team size, city, current internet, needs; GSTIN only if offered
Quote	Current monthly spend (optional)
KYC	GSTIN, Udyam number, the 4 documents
Tracker	Nothing new
Voice	Audio is turned into text and discarded, never stored

Masking in the UI and logs

GSTIN `27•••••••••1Z5` · Udyam `UDYAM-MH-00-•••4567` · ID numbers last 4 only · phone `••••••4321` · names as first name + initial. Agents and admins see masked values by default. A log filter scrubs GSTIN, Udyam, PAN and phone patterns from every log line, error included.

Encryption

- **In transit:** HTTPS only.
- **At rest:** PII columns are encrypted with Fernet (AES). Each uploaded file is encrypted separately and stored outside the web root.
- **Phone:** stored as a keyed hash, so lookup works without keeping the raw number.
- **Secrets:** environment variables only; production refuses to start with demo keys.

Retention and auto-deletion

Documents are deleted 90 days after verification, or 30 days after an abandoned case. An hourly job does the purge. Cases still under human review are skipped until they are decided.

Role-based access

Customers see only their own records. Agents see only cases assigned to them. Admins see all leads, reassignment, the outbox and the simulator. Login and OTP are rate-limited.

Audit log

Every sensitive view and action writes who, what and when: opening an escalation, viewing a lead, logging a call, viewing a KYC document.

DPDP Act 2023 mapping

Choice	DPDP point
Notice and explicit consent before KYC	s.5 notice, s.6 consent
KYC used only for verification	Purpose limitation (s.4, s.6(1))
Per-step minimisation	Only data necessary for the purpose (s.6(1))
One-tap withdrawal with deletion	Right to withdraw (s.6(4)), erasure on withdrawal (s.12)
Auto-deletion after the purpose ends	s.8(7)
Encryption, masking, access control, audit log	Reasonable security safeguards (s.8(5))
Owner can view status and their data, and ask for help	Right to information (s.11), grievance redressal (s.13)